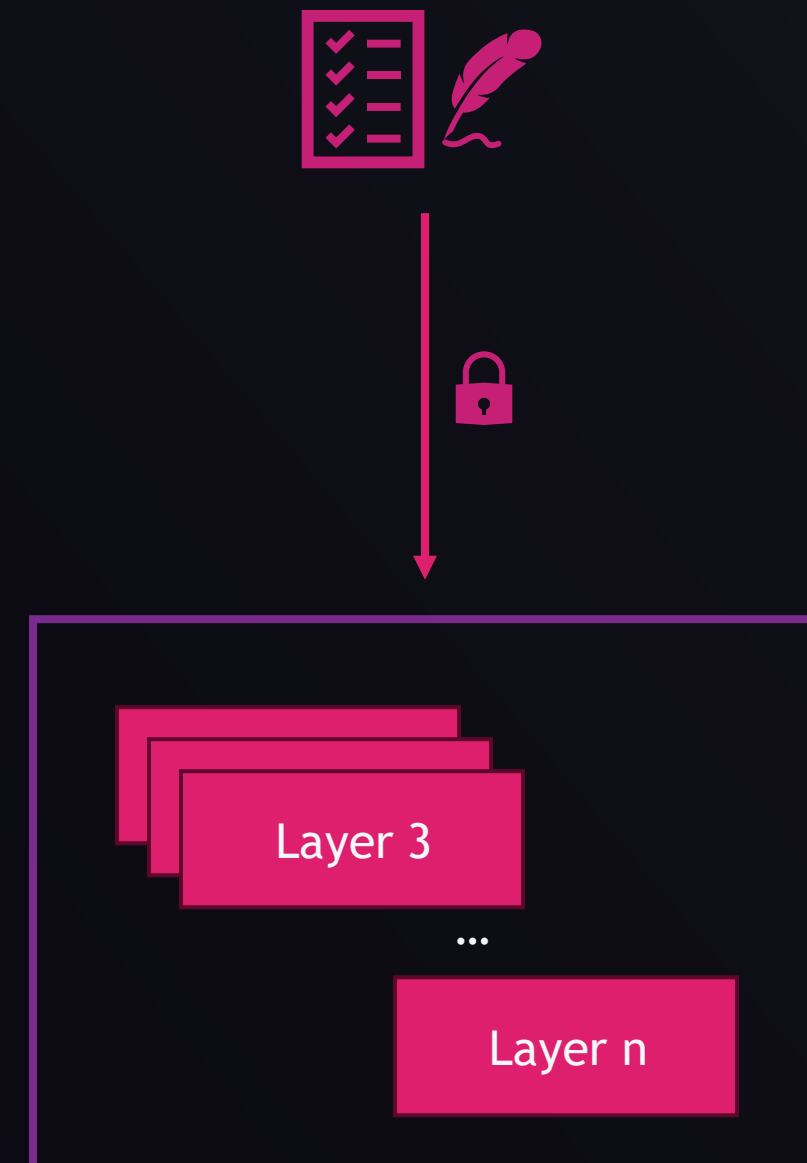


SECURING YOUR KUBERNETES SUPPLY CHAIN WITH CONTAINER IMAGE SIGNING

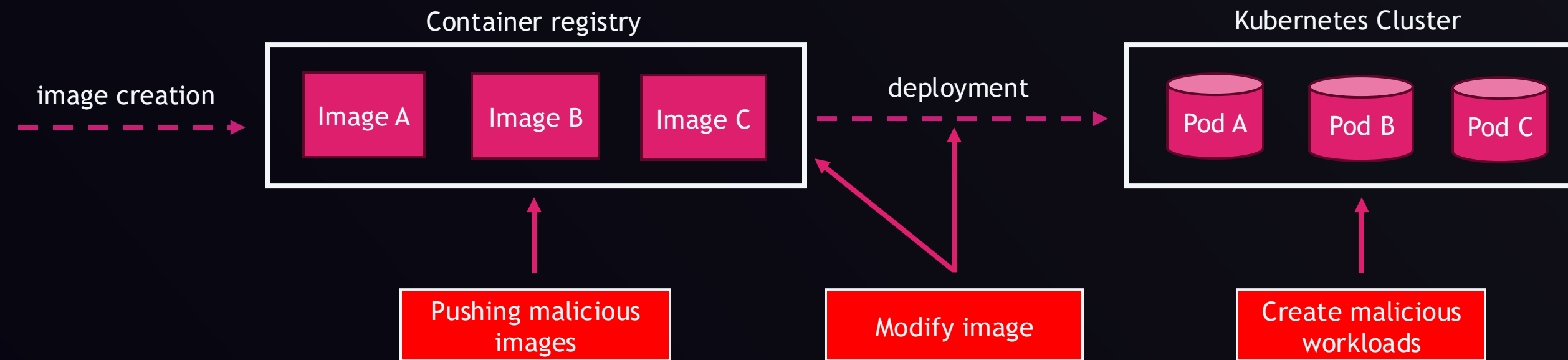
2025

CONTAINER IMAGE SIGNING

- default: container images are „anonymous“
- add digital cryptographic signature to a container image
- ensures its authenticity and integrity
- signature is created based on the image digest



BENEFITS



- signature is created based on the image digest
- digest is computed from each image layer
- verify that image is from a trusted publisher
- useful for auditing purposes, helping organizations to track the origins

Benefits

- protection against image tampering/modifications

COSIGN



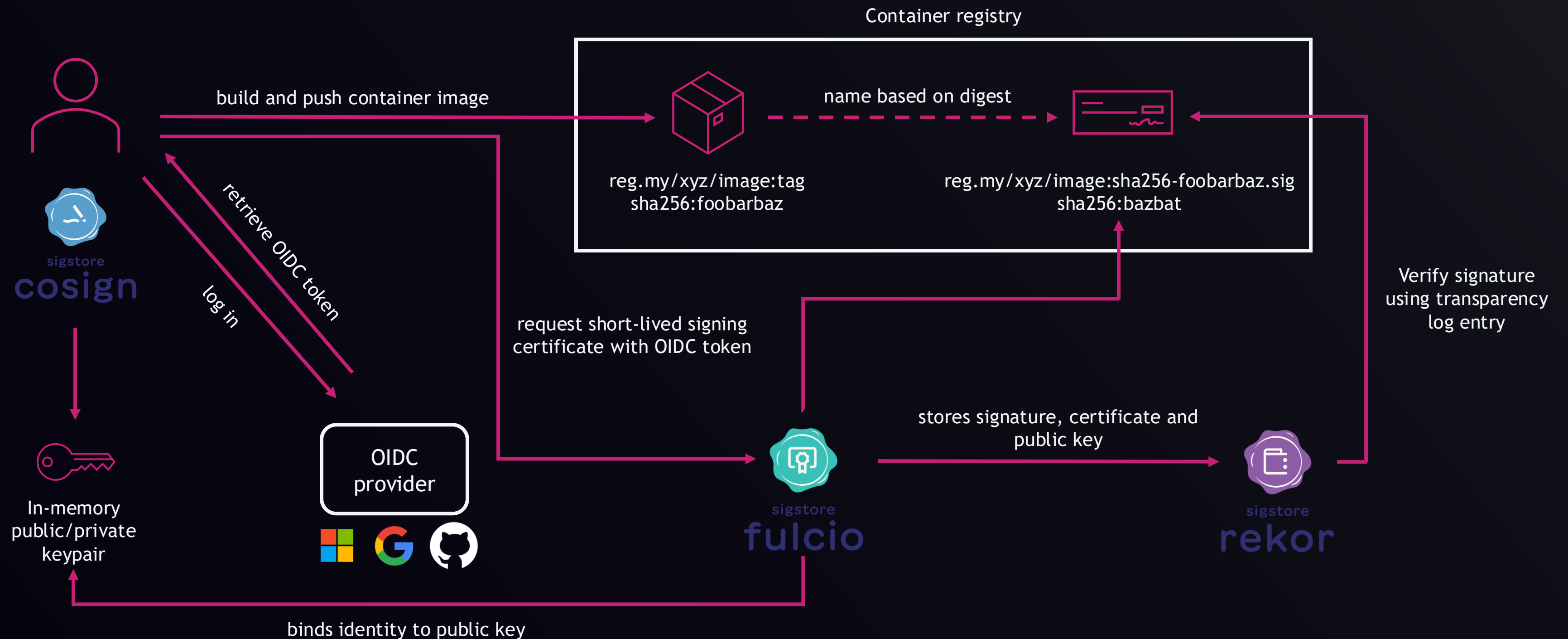
sigstore
cosign

- popular tool for signing container images
- can also be used to sign other artifacts like generic blobs, scripts or configuration files

Two approaches:

- signing with generated public/private keypair
- keyless (OIDC-based) signing using Fulcio and Rekor

KEYLESS COSIGN



DEMO TIME



Cosign - Github



Demo - Repository



Contact/LinkedIn

THANK YOU! - Q&A